

Annexe technique

Sécurité & conformité RGPD

Politique de sécurité et protection des données personnelles — MVP Wallet

Objet de ce document

Ce document consolide et étend la section 4 du cahier des charges. Il couvre le modèle de menaces, les mesures de sécurité techniques, la politique de gestion des secrets, et l'ensemble des obligations RGPD applicables au projet wallet — de la classification des données aux droits des utilisateurs, en passant par le registre simplifié des traitements.

Il constitue une annexe autonome, défendable en soutenance comme preuve de la maturité de la démarche de conception.

1. Modèle de menaces (STRIDE)

L'analyse des menaces suit la méthodologie STRIDE (Microsoft Threat Modeling), appliquée aux actifs critiques du wallet : comptes utilisateurs, wallets, transactions locales et inter-wallets.

Actifs à protéger

- Données d'authentification : e-mails, mots de passe hashés, tokens JWT
- Données financières : soldes des wallets, historique et montants des transactions
- Protocole inter-wallets : intégrité et authenticité des payloads échangés
- Infrastructure : base de données PostgreSQL, API Next.js, environnement Docker

Catégorie	Menace	Vecteur dans ce projet	Contre-mesure MVP
Spoofing	Usurpation d'identité	Connexion avec les credentials d'un autre utilisateur	bcrypt + JWT signé + durée de vie courte (15 min)
Tampering	Falsification d'un payload inter-wallets	Modification du montant ou du wallet destinataire en transit	Signature HMAC-SHA256 obligatoire + TLS
Repudiation	Déni d'une transaction effectuée	Un utilisateur conteste avoir initié un virement	Audit trail complet (InterWalletLogs + Transactions)
Info Disclosure	Exposition de données personnelles	Fuite de l'historique de transactions ou des soldes	JWT pour l'accès API + TLS en transit
Denial of Service	Saturation des endpoints de paiement	Flood de POST /inter-wallet/transfer	Rate limiting (429) — à implémenter Sprint 1
Elevation of Privilege	Accès aux wallets d'un autre utilisateur	Manipulation des IDs dans les requêtes API	Vérification propriétaire wallet côté serveur à chaque appel

Menaces explicitement hors périmètre MVP

- Attaques sur la chaîne d'approvisionnement (supply chain) — npm audit recommandé en CI post-MVP
- Attaques par canal auxiliaire sur le serveur (side-channel) — niveau production bancaire
- DDoS distribué à grande échelle — CloudFlare ou WAF en post-MVP

- Phishing ciblé sur les utilisateurs — awareness et 2FA post-MVP
-

2. Mesures de sécurité techniques

Cette section consolide toutes les mesures de sécurité du cahier des charges (sections 3, 4, 6) et y ajoute les éléments manquants : durée de vie des tokens, rate limiting et gestion des secrets.

2.1 Vue d'ensemble des mesures

Légende — Statut : Inclus MVP = implémenté dans le périmètre actuel. À implémenter = prévu dans les sprints restants. Post-MVP = roadmap.

Mesure	Technologie	Statut MVP	Justification
Authentification	JWT (HS256)	Inclus	Accès sécurisé aux endpoints API
Durée de vie JWT	15 min access / 7j refresh	Inclus	Limite la fenêtre d'exploitation d'un token volé
Hachage mots de passe	bcrypt (cost factor 12)	Inclus	Résistance aux attaques par dictionnaire
Chiffrement en transit	TLS 1.2+ (HTTPS obligatoire)	Inclus	Confidentialité de tous les échanges
Intégrité inter-wallets	HMAC-SHA256 sur payload	Inclus	Détection de toute falsification en transit
Validation des entrées	Zod / Joi sur tous les endpoints	Inclus	Prévention injection, types invalides
Rate limiting	429 sur /auth/* et /inter-wallet/*	À implémenter	Protection contre les attaques par force brute et flood
Rotation des clés HMAC	Rotation mensuelle via variable d'environnement	À implémenter	Limite l'impact d'une compromission de clé
Audit trail	InterWalletLogs + Transactions	Inclus	Traçabilité complète pour conformité et débogage
Détection de fraude	Moteur de règles + scoring	Inclus	Blocage automatique des transactions à risque élevé
Chiffrement au repos	PostgreSQL + chiffrement colonne	Post-MVP	Données sensibles chiffrées en base
SIEM / supervision	Centralisation des logs de sécurité	Post-MVP	Détection d'incidents en temps réel

2.2 Politique JWT

Access token : durée de vie 15 minutes. Contient user_id et wallet_ids associés. Signé HS256 avec JWT_SECRET.

Refresh token : durée de vie 7 jours. Stocké côté client en cookie HttpOnly Secure SameSite=Strict.

Révocation : liste noire en Redis (post-MVP) ou rotation du JWT_SECRET en cas de compromission.

Vérification propriétaire : chaque endpoint vérifie que le wallet_id dans la requête appartient bien à l'utilisateur extrait du JWT — jamais de confiance implicite.

2.3 Rate limiting

Seuils recommandés (à implémenter en Sprint 1)

- POST /auth/login : 5 tentatives / 15 min par IP → 429 + délai exponentiel
- POST /api/transactions : 20 requêtes / minute par utilisateur authentifié
- POST /api/inter-wallet/transfer : 10 requêtes / minute par wallet source
- GET /api/inter-wallet/status/* : 60 requêtes / minute (polling autorisé)

2.4 Gestion des secrets

Secret	Stockage	Règle de rotation
JWT_SECRET	Variable d'environnement (non committée)	Rotation tous les 90 jours ou si compromission
HMAC_SECRET (inter-wallets)	Variable d'environnement partagée entre wallets	Rotation mensuelle — les deux wallets doivent synchroniser
DATABASE_URL	Variable d'environnement (non committée)	À chaque changement de credentials BDD
Mots de passe utilisateurs	bcrypt hash en base (jamais en clair)	Non applicable — hash non réversible

Règle absolue

Aucun secret ne doit apparaître dans le code source, les fichiers de configuration versionnés (.env.example sans valeurs réelles), ou les logs applicatifs. Le fichier .env est exclu du dépôt Git via .gitignore. En CI/CD, les secrets sont injectés via les variables d'environnement de la pipeline (GitHub Actions Secrets).

3. Conformité RGPD — Données personnelles traitées

Le service wallet collecte et traite des données personnelles au sens du RGPD (Règlement UE 2016/679). Cette section identifie chaque donnée, sa base légale, sa durée de conservation et la mesure de protection associée.

Principe de minimisation des données (Art. 5.1.c)

Seules les données strictement nécessaires à l'exécution du service sont collectées. Les champs de localisation (city, IP) sont optionnels et ne sont utilisés qu'à des fins de détection de fraude. Aucune donnée de catégorie sensible (santé, origine ethnique, opinions politiques) n'est traitée.

Donnée	Catégorie	Base légale	Durée conservation	Mesure de protection
Adresse e-mail	Donnée d'identification	Contrat (exécution du service)	Durée du compte + 3 ans	Accès restreint, TLS en transit
Mot de passe	Donnée d'authentification	Contrat	Durée du compte	bcrypt — jamais stocké en clair
Solde du wallet	Donnée financière	Contrat	Durée du compte + 5 ans (obligations légales)	Accès JWT, audit trail
Historique des transactions	Donnée financière	Contrat + Obligation légale	5 ans après la transaction	Accès restreint, InterWalletLogs
Montant + devise	Donnée financière	Contrat	5 ans	Audit trail complet
Description de transaction	Donnée comportementale	Contrat	5 ans	Saisie libre — pas de données sensibles imposées
Adresse IP (géolocalisation)	Donnée de localisation	Intérêt légitime (sécurité / fraude)	90 jours (logs applicatifs)	Pseudonymisation recommandée post-MVP
Ville (city)	Donnée de localisation	Intérêt légitime (sécurité / fraude)	90 jours	Nullable, collectée si disponible
Identifiant utilisateur (cuid)	Donnée technique	Contrat	Durée du compte + 5 ans	Pseudonyme — ne permet pas l'identification directe

4. Registre simplifié des traitements (Art. 30 RGPD)

Le responsable de traitement est l'entité juridique opérant le service wallet. Ce registre est obligatoire pour toute organisation traitant des données personnelles à grande échelle ou de manière systématique.

Traitement	Finalité	Données concernées	Base légale	Sous-traitants
Création de compte	Permettre l'accès au service wallet	E-mail, mot de passe hashé	Contrat	Aucun (données en BDD interne)
Authentification	Vérifier l'identité de l'utilisateur	E-mail, hash bcrypt, JWT	Contrat	Aucun
Gestion des wallets	Créer et gérer les portefeuilles numériques	Solde, adresse wallet, user_id	Contrat	Aucun
Transactions locales	Permettre les transferts entre wallets internes	Montant, wallets, statut, description	Contrat	Aucun
Transactions inter-wallets	Permettre les transferts vers wallets tiers	Payload complet, IP, géolocalisation	Contrat	Wallet tiers (partenaire)
Détection de fraude	Protéger les utilisateurs et le système	Historique, fréquence, montants, IP	Intérêt légitime	Aucun
Journalisation (audit)	Traçabilité, conformité, débogage	IDs, statuts, timestamps, signature	Obligation légale / Intérêt légitime	Hébergeur cloud (AWS/GCP)
Hébergement cloud	Infrastructure d'exécution du service	Toutes les données traitées	Contrat (sous-traitance)	AWS ou GCP — contrat DPA requis

Note sur le sous-traitant cloud

L'hébergeur cloud (AWS ou GCP) est un sous-traitant au sens de l'Art. 28 RGPD. Un Data Processing Agreement (DPA) doit être signé avant la mise en production. AWS EU (Frankfurt ou Paris) et GCP EU (Belgium) proposent des DPA conformes RGPD disponibles en ligne. Les données ne doivent pas transiter hors de l'Espace Économique Européen sans mécanisme de transfert adéquat (clauses contractuelles types ou décision d'adéquation).

5. Droits des utilisateurs (Art. 15 à 22 RGPD)

Le RGPD accorde aux utilisateurs six droits fondamentaux sur leurs données personnelles. Cette section précise comment chacun est implémenté techniquement dans le wallet.

Droit RGPD	Ce que cela implique techniquement	Implémentation prévue
Droit d'accès (Art. 15)	Fournir toutes les données personnelles détenues sur l'utilisateur	Endpoint GET /api/users/me/data — export JSON complet
Droit de rectification (Art. 16)	Permettre la correction de l'e-mail	Endpoint PATCH /api/users/me — champs modifiables uniquement
Droit à l'effacement (Art. 17)	Supprimer le compte et anonymiser les données	Endpoint DELETE /api/users/me — soft delete + anonymisation des logs (conservation légale 5 ans)
Droit à la portabilité (Art. 20)	Export des données dans un format lisible par machine	GET /api/users/me/export — JSON structuré (transactions, wallets)
Droit d'opposition (Art. 21)	S'opposer aux traitements basés sur l'intérêt légitime (fraude, logs)	Interface utilisateur : toggle opt-out géolocalisation + procédure email pour opposition logs
Droit à la limitation (Art. 18)	Geler le traitement sans supprimer les données	Flag account_frozen en base + suspension des traitements actifs

5.1 Procédure de suppression de compte — Détail

Distinction suppression vs anonymisation

La suppression totale des données financières est impossible en pratique : les obligations légales (Code monétaire et financier, lutte anti-blanchiment) imposent une conservation de 5 ans après la dernière transaction.

La procédure retenue est donc :

- Compte : désactivé immédiatement (soft delete), e-mail anonymisé en deleted_HASH@wallet.local
- Données d'authentification : supprimées (e-mail, hash bcrypt)
- Transactions : conservées 5 ans avec user_id anonymisé (hash non réversible)
- Logs inter-wallets : conservés 5 ans, IP purgée à 90 jours
- L'utilisateur reçoit une confirmation par e-mail avec le détail de ce qui a été supprimé et de ce qui est conservé, ainsi que la base légale de cette conservation.

5.2 Information des utilisateurs (Art. 13 RGPD)

Avant toute collecte, l'utilisateur doit être informé. Les documents obligatoires à produire avant la mise en production sont :

- Politique de confidentialité : accessible depuis toutes les pages, rédigée en langage clair
 - Conditions Générales d'Utilisation (CGU) : acceptation explicite obligatoire à la création de compte
 - Notice de consentement pour la géolocalisation : si city/IP sont collectés, un consentement distinct est requis
 - Mention légale : identité du responsable de traitement, coordonnées de contact RGPD
-

6. Analyse des risques RGPD

Cette analyse identifie les risques spécifiques liés à la protection des données personnelles, distincts des risques de sécurité informatique couverts en section 1.

Risque identifié	Probabilité	Impact	Mesure de mitigation
Fuite de la base de données	Faible	Critique	bcrypt sur mdp, TLS, chiffrement au repos post-MVP, accès BDD restreint par IP
Token JWT volé (XSS)	Moyenne	Élevé	Durée de vie courte (15 min), refresh token HttpOnly, headers CSP
Accès non autorisé aux données d'un autre utilisateur	Faible	Élevé	Vérification propriétaire wallet à chaque appel API — jamais confiance aveugle au JWT seul
Logs d'audit conservés trop longtemps	Moyenne	Moyen	Politique de rétention automatique : purge après 90 jours pour les logs techniques
Sous-traitant cloud non conforme RGPD	Faible	Élevé	Choisir AWS EU ou GCP EU + signer un DPA (Data Processing Agreement)
Collecte excessive de données de localisation	Moyenne	Moyen	Rendre city et IP optionnels — collecte uniquement si nécessaire à la détection de fraude
Absence de consentement explicite	Élevée (si non traité)	Élevé	Page CGU + politique de confidentialité obligatoires avant création de compte

Privacy by Design — Principes appliqués (Art. 25 RGPD)

- Minimisation : seuls les champs nécessaires sont collectés — city et IP sont optionnels
- Pseudonymisation : les user_id sont des cuid() non prévisibles, distincts de l'e-mail
- Sécurité par défaut : TLS obligatoire, JWT requis sur tous les endpoints protégés
- Transparence : politique de confidentialité lisible par des non-juristes
- Durée limitée : politique de rétention automatique définie avant mise en production

7. Roadmap sécurité & RGPD post-MVP

Les éléments suivants sont volontairement exclus du périmètre MVP et constitueront les priorités de la phase d'industrialisation.

Fonctionnalité	Priorité post-MVP	Justification du report
Authentification 2FA	Haute	Ajoute une couche critique pour un service financier — TOTP ou SMS
Chiffrement au repos (BDD)	Haute	Protège les données en cas de compromission du serveur
DPO désigné	Haute	Obligatoire si traitement à grande échelle de données financières
PIA (Privacy Impact Assessment)	Haute	Requis avant mise en production réelle d'un service de paiement
SIEM et alertes sécurité	Moyenne	Détection d'incidents en temps réel — non critique pour le MVP scolaire
Rotation automatique des clés	Moyenne	Réduit la fenêtre d'exploitation en cas de fuite de clé HMAC
Pseudonymisation IP en logs	Moyenne	Conformité RGPD renforcée sur les données de localisation
Audit de sécurité externe	Basse (MVP)	Pentest recommandé avant ouverture à des utilisateurs réels
Détection fraude par ML	Basse (MVP)	Nécessite un volume de données suffisant — moteur de règles d'abord

— Fin de l'annexe —